ESEN

CIBERSEGURIDAD

Registro de supuestos, puntos únicos de falla y brechas

Donde vive la evidencia del rigor del análisis

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 06 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Cómo se llena..... 3
3. Registro de supuestos y análisis de sensibilidad..... 3
4. Puntos únicos de falla identificados..... 5
5. Brechas detectadas por el análisis..... 6
6. Valoración con rangos: la alternativa FAIR..... 6
7. Glosario de los campos de esta plantilla..... 7

Ejemplo resuelto de cátedra · anexo 6 de 7. Aquí vive la evidencia del rigor del análisis: todo dato que el perfil del catálogo no declara aparece con su identificador, su origen y su rango.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.º 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Iván Cardoza Linares, oficial de calidad, con los dos analistas de riesgos
Fecha de elaboración	14 de octubre de 2026
Versión del documento	v1.0

2. Cómo se llena

Todo análisis de impacto descansa en estimaciones, y una conclusión que solo se sostiene con la estimación más optimista no es una conclusión. Cada supuesto se declara con su origen y su fecha, se varía en tres escenarios y se observa cuánto se mueve el resultado. Si la recomendación se mantiene en los tres escenarios, es robusta y se presenta como tal; si cambia de signo al variar un solo supuesto, la recomendación depende de ese supuesto y el informe ejecutivo debe decirlo con esas palabras.

3. Registro de supuestos y análisis de sensibilidad

ID (S-nn, global)	Supuesto declarado	Valor usado	Origen y fecha de la fuente	Mínimo	Esperado	Máximo	Efecto sobre la conclusión
S-06	Sin uso: las doce subestaciones principales con equipo de control conectado al SCADA son un dato de la ficha, y un dato de la ficha nunca se sustituye por un supuesto; el identificador se conserva para no alterar la numeración global	Dato de la ficha: 12	Ficha de datos del cliente, bloque «Economía»	8	12	20	Dimensiona el MBCO y el costo del procedimiento alterno; no altera el MTPD

ID (S-nn, global)	Supuesto declarado	Valor usado	Origen y fecha de la fuente	Mínimo	Esperado	Máximo	Efecto sobre la conclusión
S-07	Entrevistas, participantes y fechas del levantamiento	Cinco dueños de proceso	Supuesto del ejercicio; el perfil no describe personas · 6 oct 2026	—	—	—	Sin efecto sobre las cifras; sostiene la trazabilidad del método
S-08	Sin uso: los ingresos no percibidos por hora de indisponibilidad del telecontrol se derivan de la ficha, 190 MW de demanda media × USD 200 por MWh; el identificador se conserva	Derivación de la ficha: USD 38 000	Ficha de datos del cliente, bloque «Economía»: demanda de 120 a 275 MW	24 000	38 000	55 000	Gobierna el costo por hora y el costo al MTPD; la conclusión se mantiene en los tres escenarios
S-09	Sin uso: las compensaciones contractuales a clientes industriales son un dato de la ficha; el identificador se conserva	Dato de la ficha: USD 4 500 por hora	Ficha de datos del cliente, bloque «Operación por proceso», penalizaciones del SCADA	2 000	4 500	9 000	Efecto menor sobre el total; no cambia ninguna clasificación
S-10	Sin uso: el AV del proceso de control de red se deriva de la ficha, USD 6,0 M de margen de la energía que distribuyen las doce subestaciones más USD 3,0 M de reposición de la plataforma SCADA; el identificador se conserva	Derivación de la ficha: USD 9 000 000	Ficha de datos del cliente, bloque «Economía»: margen de 4,5 a 8,0 M y reposición de 2,0 a 4,0 M	6 500 000	9 000 000	12 000 000	Gobierna el SLE y, con él, el ALE de E.05; la justificación de los controles 12 y 13 se sostiene incluso en el mínimo
S-11	Criterio de desempate entre procesos con igual puntaje: mayor costo de indisponibilidad por hora	Aplicado a P-04 y P-02 (2,46)	Decisión del equipo registrada en acta · 13 oct 2026	—	—	—	Solo altera el orden entre dos procesos importantes
S-12	EF del evento de referencia sobre el SCADA (cifrado o manipulación con 24 h de indisponibilidad)	0,55	Criterio del dueño del proceso y costo por día · 8 oct 2026	0,40	0,55	0,70	Variable que más mueve el SLE; se somete a sensibilidad en la sección 6 y en E.05, tabla D.7
S-13	Sin uso: la duración máxima sostenible del procedimiento alterno del SCADA es un dato de la ficha; el identificador se conserva	Dato de la ficha: 12 horas con un solo relevo	Ficha de datos del cliente, bloque «Operación por proceso»; el simulacro de marzo de 2026 lo sostuvo 8 horas con relevo completo	8	12	16	Si el mínimo se confirma, el MTPD debería revisarse a la baja: es la variable que la dirección debe validar primero
S-14	Presupuesto de seguridad de 2028 y 2029 igual al de 2027	USD 480 000	Ficha de datos del cliente, bloque «Organización y presupuesto»: 480 000 aprobados para 2027; 2028 y 2029 sujetos a aprobación, entre 300 000 y 600 000	300 000	480 000	600 000	Techo del ACC de los controles; con el mínimo, el roadmap de E.10 desplaza dos iniciativas al mediano plazo

Las variables que más mueven el resultado son las que gobiernan la conclusión, y son las que el informe ejecutivo nombra.

4. Puntos únicos de falla identificados

Cada punto único de falla se registra con su proceso y pasa al informe ejecutivo. Los del caso resuelto de la Guía del Estudiante son la segmentación laxa entre la red administrativa y la médica y la ausencia de inventario de los dispositivos médicos conectados; cada equipo identifica al menos dos en su propia empresa.

N.º	Punto único de falla	Proceso afectado	Consecuencia si falla	Alternativa propuesta	Prioridad
SPOF-01	Un solo ingeniero con credenciales y conocimiento de administración del SCADA	P-01, P-03	Sin capacidad de recuperar la plataforma dentro del RTO de 2 horas; dependencia del soporte del fabricante con respuesta de 8 horas	Documentar la configuración, formar a un segundo ingeniero y contratar respuesta de 4 horas con el fabricante	Alta
SPOF-02	Centro de control de red sin redundancia geográfica ni puesto de mando equipado	P-01, P-03	La indisponibilidad de la sala deja la red sin telecontrol durante todo el evento	Equipar el puesto de mando móvil con dos HMI y enlace de radio	Alta
SPOF-03	Autenticación de los operadores dependiente del directorio corporativo de TI	P-01	Un incidente en la red de TI impide operar la red eléctrica	Cuentas locales de emergencia en sobre sellado y autenticación independiente para el entorno OT	Alta
SPOF-04	Acceso remoto de mantenimiento del proveedor SCADA sin autenticación multifactor ni registro	P-01	Vía de entrada directa al entorno de control desde fuera de la organización	Concentrador de acceso con multifactor, aprobación por sesión y grabación	Crítica
SPOF-05	Un único concentrador de datos AMI por zona, sin reserva	P-02	Pérdida de lectura de la zona durante el ciclo, con estimación obligada	Reserva fría de concentradores y procedimiento de sustitución en 24 horas	Media
SPOF-06	Enlace único del sistema comercial con la pasarela de pagos	P-04	Cobro en línea detenido durante el evento	Segundo proveedor de pagos con conmutación manual	Media
SPOF-07	Radio troncalizado con repetidores en tres cerros, sin respaldo de energía en uno de ellos	P-01, P-03, P-06	El medio alterno del MBCO se degrada justo en la contingencia	Planta de respaldo y prueba trimestral en el repetidor descubierto	Media
SPOF-08	Respaldo de la configuración del SCADA en cinta semanal, sin copia aislada verificada	P-01	Restauración fuera del RPO de 15 minutos y del RTO de 2 horas	Respaldo diario con copia aislada e inmutable y prueba de restauración trimestral	Crítica

5. Brechas detectadas por el análisis

Una brecha es una diferencia verificada entre lo que el proceso necesita y lo que la organización tiene. Se registra con su evidencia, con el control que la cerraría y con la referencia al marco correspondiente.

Brecha	Evidencia que la sostiene	Control propuesto	Referencia CIS v8.1 o NIST CSF 2.0	Prioridad
B-01 El respaldo vigente no sostiene el RPO de 15 minutos ni el RTO de 2 horas del SCADA	Respaldo en cinta semanal, sin prueba de restauración documentada (revisión documental del 8 de octubre)	Respaldo automatizado, copia aislada e inmutable y pruebas de restauración periódicas	CIS 11.2, 11.3, 11.4, 11.5 · CSF 2.0 RC.RP	Crítica
B-02 Los puntos de conexión entre la red de TI y la red OT no atraviesan un filtro documentado	El propio perfil declara que el aislamiento no es real	Segmentación con zona intermedia y reglas aprobadas y revisadas	CIS 12.2, 12.4, 12.8 · CSF 2.0 PR.IR	Crítica
B-03 No existe inventario de los activos de la red OT ni de los concentradores AMI	Entrevista con TI/TO del 7 de octubre: el inventario cubre solo la red corporativa	Inventario de activos con descubrimiento pasivo en OT	CIS 1.1, 1.2, 1.5 · CSF 2.0 ID.AM	Alta
B-04 Sin monitoreo de seguridad en la red OT ni recolección centralizada de bitácoras	No hay herramienta de detección en OT y las bitácoras quedan en cada equipo	Detección pasiva de intrusiones en OT y centralización de bitácoras	CIS 8.2, 8.9, 13.1, 13.5 · CSF 2.0 DE.CM	Alta
B-05 El acceso remoto de proveedores carece de multifactor y de registro por sesión	Contrato de soporte revisado el 8 de octubre: acceso permanente con usuario compartido	Multifactor, cuenta nominal por técnico y grabación de sesión	CIS 6.3, 6.5, 6.7, 15.4 · CSF 2.0 PR.AA	Crítica
B-06 No hay ventana de mantenimiento ni proceso de parcheo para servidores y HMI del entorno OT	Entrevista con TI/TO: el parcheo se hace cuando el fabricante lo autoriza, sin calendario	Gestión de vulnerabilidades con ventana declarada y remediación por riesgo	CIS 7.1, 7.2, 7.5, 7.7 · CSF 2.0 ID.RA	Alta
B-07 La videovigilancia de subestaciones queda fuera del alcance con convergencia no resuelta hacia la red OT	Exclusión declarada en E.02 y confirmada en el taller del 2 de octubre	Revisión de la conexión de los equipos de video y su segmentación	CIS 12.2 · CSF 2.0 ID.AM	Media
B-08 La competencia de administración del SCADA no está documentada ni replicada	SPOF-01	Documentación de la configuración y formación de un segundo ingeniero	CIS 14.1 · CSF 2.0 GV.RR	Alta

6. Valoración con rangos: la alternativa FAIR

El análisis factorial del riesgo de la información es una taxonomía publicada por The Open Group en sus normas Open FAIR: la de taxonomía Risk Taxonomy O-RT en su versión 3.0.1 y la de análisis Risk Analysis O-RA en su versión 2.0.1, ambas de noviembre de 2021. Descompone el riesgo en la frecuencia de los eventos de pérdida y la magnitud de la pérdida, y esta última en pérdida primaria, la que sufre la organización de forma directa, y pérdida secundaria, la que proviene de la reacción de terceros: multas, litigios y respuesta de los clientes. Trabaja con rangos y

distribuciones de probabilidad en lugar de valores puntuales, lo que encaja cuando los datos históricos escasean, que es la situación de las empresas del catálogo. Esta sección se llena cuando el equipo elige explorar la alternativa.

Factor	Rango mínimo	Rango esperado	Rango máximo	Fundamento del rango
Frecuencia de eventos de pérdida	0,2 al año	0,5 al año	1,0 al año	Frecuencia de campañas de ransomware con efecto sobre entornos de tecnología de operación en el sector eléctrico de la región; el valor esperado corresponde al nivel 4 de la escala de probabilidad de E.05
Magnitud de la pérdida primaria	USD 2 600 000	USD 4 950 000	USD 8 400 000	AV entre USD 6,5 y 12 millones con EF entre 0,40 y 0,70 (AV derivado de la ficha y supuesto S-12)
Magnitud de la pérdida secundaria	USD 150 000	USD 420 000	USD 1 100 000	Sanción regulatoria, compensaciones a clientes industriales y costo de comunicación de crisis
Magnitud total de la pérdida	USD 2 750 000	USD 5 370 000	USD 9 500 000	Suma de las dos anteriores en cada escenario

Comparación con el resultado obtenido por el método de valores puntuales, y criterio del equipo sobre cuál conviene en este caso:

La valoración con rangos se incluye porque el supuesto S-12 (factor de exposición) es el que más mueve el resultado. La conclusión del análisis —que el tratamiento de los riesgos sobre el entorno SCADA se justifica económicamente— se mantiene en los tres escenarios, y así lo declara el informe ejecutivo de BIA_P07.

7. Glosario de los campos de esta plantilla

Término	Definición
Supuesto declarado	Estimación que sostiene una cifra del análisis, registrada con su origen y su fecha.
Análisis de sensibilidad	Variación de cada supuesto en escenarios mínimo, esperado y máximo para observar cuánto se mueve el resultado.
Pérdida primaria	Pérdida que la organización sufre de forma directa por el evento.
Pérdida secundaria	Pérdida que proviene de la reacción de terceros: multas, litigios y respuesta de los clientes.
Brecha	Diferencia verificada entre lo que el proceso necesita y lo que la organización tiene.